Policy 2 – Risk Management

1. Table of Contents

1 Document Content Page

2 Policy Objectives and Scope

2.1 Purpose

2.2 Scope

2.3 Risk Identification & Register

2.4 Risk Assessment & Prioritization

2.5 Risk Treatment

2.6 Threat Intelligence

3 Policy Compliance

3.1 Compliance Measurement

3.2 Exceptions

3.3 Non-Compliance

3.4 Continual Improvement

2. Policy Objectives and Scope

2.1 Purpose – Identify, rank and address material risks in a repeatable, lightweight manner.

2.2 Scope – Strategic, operational, technical, vendor, legal and financial risks affecting the organization.

2.3 Risk Identification & Register

- Maintain a single **Risk Register** on Comp AI platform that contains: Risk, Impact, Likelihood, Owner, Treatment.
- Add or update entries when launching new services, adopting vendors, or learning of relevant threat events.
- Ensure the register is never blank.

2.4 Risk Assessment & Prioritization

- Use simple 1-5 scoring for Impact and Likelihood.

- Highlight the three highest-scoring risks each quarter.
- Record rationale for any score change.

2.5 Risk Treatment

- Choose a response for highlighted risks: **Mitigate, Transfer, Avoid, Accept**.
- Create one actionable task with a due date for each decision other than Accept.
- Mark “Accepted” items with date and approving manager initials.

2.6 Threat Intelligence

- Subscribe to reputable free alerts (e.g., national CERT, CISA, major cloud vendor advisories).
- Post relevant items to an internal threat-intel channel and add new risks or actions when applicable.

3. Policy Compliance

3.1 Compliance Measurement – Register exists, three risks flagged, and no mitigation task more than 30 days overdue.

3.2 Exceptions – Acceptance of any High-impact risk requires documented senior-management approval.

3.3 Non-Compliance – Register empty or stale (>90 days) triggers discussion at the next management meeting until resolved.

3.4 Continual Improvement – Closed or obsolete risks are removed during quarterly review to keep the list concise.